

ver GitLab-managed channels like email, Slack, Zoom, GitLab.com issues and merge requests, etc.

- Creating web sites that appear to be legitimate copies of items in our tech stack, sending the URLs to team members over those GitLab-managed channels, collecting credentials entered into those sites and attempting to re-use them in the legitimate application.

- Sending calendar invites and meeting requests over those GitLab-managed channels, and speaking over voice or video call with team members who join those meetings or call the provided numbers.

- Other forms of social engineering that impersonate GitLab team members, vendors, customers, partners, etc. and are directed towards GitLab owned or managed services such as email, authentication providers, job postings, etc. where the social engineering attempts do not directly target personal devices or services.

Execute supply-chain related attack techniques like dependency confusion, pipeline injections, and malicious code commits.

If you are a team member at GitLab and suspect you have uncovered a stealth red team operation in the course of your daily work, please first report this to your manager and refer to the "Is This Red Team?" section.

At this time, the Red Team will not:

- Attempt to access resources inside a GitLab team member's home (wireless networks, non-GitLab machines, etc).

- Attempt to access the camera or microphone on any device without explicit permission from its owner.

- Attempt to socially engineer team members via channels not managed by GitLab (such as social networks, personal email addresses, etc).

- Directly call or SMS team member's personal phone numbers, except in the case where team members explicitly opt-in and actively provide their contact information on a volunteer basis.

- Attempt to access the web browsing history of any team member.

- Attempt to gain access to anything that is not strictly work-related and managed/owned by GitLab.

Auditing Red Team Attack Techniques

The Red Team maintains operator logs which include specific details on attack techniques we've conducted, timestamps, source IP addresses, etc. These are included in an operation's final report, but will be redacted to not show specific names of accounts and laptops that may have been compromised.

If a team member's account or laptop is compromised during an operation, the Red Team will share specific details of all related activity with that team member. This will include the operator logs. The Red Team will offer to meet with them synchronously to explain these logs, if the team member would like that.

Besides these manual logs, our activities can be audited using the same capabilities GitLab has to investigate actual malicious activity. For example, any commands we may execute on a "compromised" laptop should be captured and archived by our endpoint detection and response (EDR) software.

SECTION: security/security-operations/red-team/opportunistic-attacks/_index.md

Opportunistic attacks are short (ideally a few days at most) more spontaneous initiatives than Stealth Operations.

They can be done at any time, from any source IP address, and against any GitLab-managed asset without prior approval or notification.

Benefits include:

- They give GitLab more opportunities to practice detecting and responding to realistic threats in a controlled environment, allowing faster iteration on our defensive capabilities and investigation skills.
- They allow us to quickly demonstrate the impact of security concerns.
- They allow us to quickly act on this intelligence and demonstrate the impact of the security concern.

If vulnerabilities are discovered, we exploit them and work to safely demonstrate maximum impact. This may involve establishing persistence, escalating privileges, and other common attack techniques.

When immediate action is required, we follow the standard process for reporting an incident. For vulnerabilities that appear wide-spread or recurring, we create an issue inside the Vulnerability Management issue tracker to implement automated scanning capabilities.

We list examples of opportunistic attack techniques inside our rules of engagement.

Club Red

Club Red is our program that allows GitLab team members to help us discover and develop initial access vectors and optionally, collaborate with us to carry them out.

Occasionally team members reach out with a cool hack idea, often based on knowledge they have. Club Red aims to provide a way for them to collaborate with us develop their idea for a greater overall security result for GitLab.

If you are an internal GitLab team member with an interesting idea, please contact us.

SECTION: security/security-operations/red-team/purple-teaming/_index.md

The terms "Red Team" and "Blue Team" are used to describe the roles of attackers and defenders during planned security exercises. At GitLab, where collaboration and transparency are two of our core values, we like to join forces and conduct what is commonly referred to as "Purple Teaming".

GitLab team members can contribute, comment, view, or interact with us on Slack in the purple-team-ops channel where we discuss ongoing purple-team operations.

Goals of Purple Teaming

Purple Team operations help GitLab to better understand our organization's ability to detect and respond to real-world attacks. Given this deeper understanding, we can continue to strengthen these defenses based on the hands-on experience gained during emulated attacks, as opposed to the real thing.

At a high level, the goals of an operation generally fall into one of the following categories:

- To gauge the effectiveness of existing defensive capabilities (Is our SIEM capable of detecting a compromised admin account?)
- To practice and refine our procedures for responding to a breach (Do our runbooks make sense? Can anything be automated?)
- To understand our ability to detect and respond to a specific type of threat (What would happen if we were targeted by a ransomware operator?)

Purple Team Operations

Flash Operations

These are very short (1-2 weeks) and start with the identification of a relevant threat. Generally Red Team members meet with Blue Team members to plan and carry out the execution.

1. We work with the Threat Intelligence team to identify one or more relevant TTPs (tool, technique and procedure) that's worth exploring collaboratively.
2. We arrange a time to run the TTP(s), usually inside a virtual machine, and the Blue Team confirms detection (or no detection).
3. The detections are created or improved, resulting in a better security result for GitLab.
4. We collaborate on a report and share it within the security division (and wider company if applicable), so everyone is aware.

Longer-term collaborations

Atomic Testing is our first long-term Purple Team collaboration, enabling the easy re-run of these TTPs, much like unit tests do.

See also Red Team Resources

SECTION: security/security-operations/red-team/purple-teaming/atomic-testing.md

Atomic Testing is a way of testing detections in a more repeatable way, similar to how software benefits from unit testing to ensure it still behaves as expected.

Detection rulesets can be vulnerable to changes in their underlying technologies, so they benefit from a repeatable testing framework to catch changes in detection efficacy and ensure they still perform as expected against malicious TTPs (tactics, techniques and procedures).

GitLab uses forks of the TTPForge and ForgeArmory frameworks and have customised the collection of provided TTPs specific to our unique tech stack.

For more information, see this epic and the Atomic Testing trial report.

Atomic Testing Process

Get ready

1. Red Team: select a TTP from GitLab's ForgeArmory fork or develop a new one. SIRT can be involved with the selection since they are familiar with the detection suite, or the Threat Intelligence team who can provide TTPs that are relevant to current threats.
2. Red Team: Do a TTP test run to ensure it works in correct environment. Spin up a standalone VM running the relevant OS and without the detection agent. This allows testing without creating unnecessary alerts. Clone and set up TTPForge and ForgeArmory from our forks and install any dependencies.
3. Red/Blue team: Create a new issue for testing the TTP under this epic
4. Red Team: Ask a SIRT member who can analyse the logs (for example, who is not on call that week)
5. Red/Blue team: Agree on a time (synchronously works best initially if possible, but not required)

Run the TTP

{:start="6"}

1. Red Team: Notify SIRT in the security-operations channel of the selected TTP (with a link to the yml file) and the machine it's being run on, so that an incident isn't raised.
1. Red Team: Run the TTP live. On a machine or VM with the detection agent installed, clone TTPForge and ForgeArmory from our forks, install dependencies. Run the TTP and immediately notify the Blue Team member to find and analyse logs.
1. Red Team: Ensure the issue created in point 3 above is updated with any commands run and output generated. Use <details> and <summary> to collapse long output sections.

Analysis and recommendation

{:start="9"}

1. Blue Team: Analyse logs and identify improvements to detections
1. Red Team: If there is a potential improvement (even if not eventually adopted), create a recommendation issue with ~RTRec::Detection and under this epic. Here's an example.
1. Blue Team: Create detection improvement MR (if applicable) and link in recommendation issue, and apply appropriate SIRT labels.
1. Red/Blue Team: Close issue with appropriate RecOutcome:: label

Repeat as needed!

SECTION: security/security-operations/security-logging/_index.md

<i class="fas fa-rocket" id="biz-tech-icons"></i> Our Vision

Guarantee that GitLab has the logging data coverage required to:

- Perform the threat analysis, alerting and threat detections necessary to protect the company and its customers
- Ensure compliance with internal policies, standards, internal and external audits, and regulatory requirements.

Our Mission Statement

The team achieves its vision by planning, executing and supporting initiatives that improve the coverage and usability of security logging data on GitLab. We manage, maintain, design, configure, and document the necessary tools, systems and processes to make that happen.

Further details can be found in the job family description.

 The Team

Team Members

The Security Logging Team is part of the Product Security sub-department. See GitLab's organizational chart and meet our team members.

Team Responsibilities

The Security Logging Team is responsible for security focused logging, monitoring, and alerting.

What we are responsible for

The Security Logging Team is responsible for managing, maintaining, designing, configuring, and documenting the necessary tools, systems and processes to support all security logging, monitoring, and alerting needs. This includes but is not limited to the following examples:

- Designing, managing, and maintaining the security logging and monitoring infrastructure
- Ensuring reliability and availability of log data for security purposes
- Owning and maintaining the security logging standard that defines important aspects and requirements of security logging, monitoring, and alerting at GitLab
- Working with our internal GitLab customers to ensure they have the logging data, and access to this data, needed to successfully accomplish the responsibilities of their roles
- Working closely with the Infrastructure team ensuring that log aggregation infrastructure is reliable and available to meet the needs of both Infrastructure and Security
- Building and maintaining a library of logging profiles for various technologies that can be used to gather, format, and send logging data to the appropriate log aggregation systems

What we are not responsible for

The Security Logging Team is not responsible for the logging, monitoring, and alerting data or infrastructure supporting non-security focused needs. This includes but is not limited to the following examples:

- Infrastructure or application logging supporting reliability or availability of GitLab systems
- Responding to or taking action on the security alerts that are generated by the infrastructure and tools owned and maintained by the Security Logging Team
- Remediation of security vulnerabilities found using the infrastructure and tools owned and maintained by the Security Logging Team
- The Security Logging Team does not own the logging data aggregated, stored, or contained within the infrastructure and tools owned and maintained by the Security Logging Team
- The Security Logging Team is not responsible for the endpoint systems from which logging data is gathered

Working With Us

1. Create an issue in our issue tracker dedicated to Business as Usual (BAU) activities and general inquiries.

- It is not necessary to @mention anyone. In case you want to mention the whole team, use the @gitlab-com/gl-security/engineering-and-research/security-logging handle on GitLab.com.
- You can also chat with us on Slack in the dedicated security-logging channel or by tagging us @security-logging-team.

How to contact us

The Security Logging Team can be contacted in Slack using the security-logging channel, the security channel, or the security-division channel. You can also contribute, comment, view, or interact with us in our team repo.

How We Work

We are an internal customer focused and customer driven team. Our customers drive our priorities and help us define our responsibilities. We work to balance this with a risk based approach aimed at reducing and minimizing security risk at GitLab. Additionally, we embrace the DevOps model, software defined infrastructures, a cloud first approach, modular decoupled architectures, self-serviceability, and automate when and wherever possible.

Meetings and Scheduled Calls

Our preference is to work asynchronously, within our project issue tracker as described in the project management section below.

The team does have set of regular synchronous calls:

- A weekly team sync to discuss progress, blockers, and anything related to the InfraSec team.
 - Everyone in the company is welcome to join.
 - The agenda is public within GitLab as well.
- A quarterly team retrospective to reflect on what went well in the previous quarter, and discuss what can be improved going forward.
- 1-1s between Individual Contributors and the Engineering Manager.

Team Pages

- This Handbook Page, which contains general information about the team.
- The Security-Logging GitLab Sub-Group, which contains EPICs and repositories

Project Management

We use Epics, Issues, and Issue Boards to organize our work, as they complement each other:

- The single source of truth for engineering work is the Security-Logging Sub-Group in GitLab. All Epics will be collected at this level.
- Having all projects at this level allows us to use a single list for prioritization and enables us to prioritize work for different services alongside each other.
- Projects are prioritized in line with Security Logging Board.

Team Planning

- For the long term strategy of the InfraSec Team, you can refer to:
 - · Sec-Logging Roadmap (tbd)
 - · Sec-Logging OKRs (tbd)
- From a tactical point of view, you can refer to:
 - · Sec-Logging Milestones (quarterly) (tbd)
 - · Sec-Logging Epics for this quarter (tbd)
 - · Sec-Logging Initiatives Board (tbd) (for the tasks we are currently working on)

Project Ownership

Each project has an owner who is responsible for delivering the project.

The owner needs to:

1. Regularly update the status in the Epic description and milestones.
1. Work with others to move project issues through the boards.

Labels

Please use the following labels for general work only:

Label	Use Case
~".. SecLog"	Team Label (to be included in every project-related issue)
~"SecLog::Incoming-Requests"	For new issues which need to be triaged

Design Documents

Before starting a new project, the team is encouraged to define software designs through design docs.

These design doc documents the high level implementation strategy and key design decisions with

emphasis on the trade-offs that were considered during those decisions.

To start discussing a new design:

1. Create a new issue in the InfraSec Team Charter repo
1. Select the design doc template
1. Fill the data as requested

Security Logging Program Roles and Responsibilities

The following roles and responsibilities are specific to the management and execution of the Security Logging Program which is overall the responsibility of the Product Security sub-department.

Security Logging is responsible for

- Ownership of, management, and maintenance of our SIEM
- Coordinating and executing log source ingestion
- Overall management and coordination of the security logging program
- Ownership of the to be developed Security Logging Standard
- Subject matter experts with regards to the operation and management of the SIEM
- The data movement and archive of security logging data currently held in Panther
- Capacity planning and forecasting of licensing and infrastructure costs, as a shared responsibility with InfraSec

AppSec is responsible for

- Working closely with Development to ensure the Security Logging Standard is adopted and followed
- Advising SecLogging when log formats will change, prior to the change occurring, if known
- Advising SIRT on any log sources from the application that they may be interested in and recommend new high-value detection considerations to SIRT for new product features or capabilities
- Helping to bridge the gap between the Security Logging Team and the software engineering teams
- Helping to identify logging gaps in the application and proposing solutions to close the gaps
- Aiding and guiding engineering teams that design, develop, or deploy something new on what to log and how to get the logs into the SIEM. This includes logs that SIRT needs to complete investigations.

InfraSec is responsible for

- Working closely with Infrastructure to ensure the Security Logging Standard is adopted and followed
- Advising SecLogging when log formats will change, prior to the change occurring, if known
- Advising SIRT on any log sources from the infrastructure that they may be interested in and recommending new high-value detection considerations to SIRT for new product features or capabilities
- Helping to bridge the gap between the Security Logging Team and the Infrastructure teams
- Helping to identify logging gaps in the infrastructure and proposing solutions to close the

gaps

- Aiding and guiding engineering teams that design, develop, or deploy something new on what to log and how to get the logs into the SIEM. This includes logs that SIRT needs to complete investigations.

Capacity planning and forecasting of licensing and infrastructure costs, as a shared responsibility with Security Logging

SIRT is responsible for

- The management and ownership of Panther until it is decommissioned
- Ensuring that they have the logging data needed to effectively and efficiently execute their responsibilities as incident responders
- Documenting gaps in logs and using the prioritization procedure to ensure prioritization meets the standards set by the procedure
- Configuring automation, alerting, and monitoring specific to their needs for incident response
- Guiding and informing the InfraSec and AppSec teams on logging data critical to SIRT through collaboration and maintenance of the development of the Security Logging Standard
- Reporting to the Security Logging Team when logs:
 - Are no longer needed
 - Are incomplete
 - Need format improvements or corrections
 - Require more verbosity
 - Have efficiency opportunities (e.g. we only use a small portion of sizable logs)

Everyone else across Security is responsible for

- Making requests of the Security Logging Team for logs that you need to execute your responsibilities, we will have a documented process for this soon
- Submitting issues to SIRT when you have detection suggestions where we have a high return on investment

Additional Resources

Onboarding

- Infrastructure Security Team Onboarding Template
- InfraSec Entitlements template

SECTION: security/security-operations/security-logging/critical-logging-methodology.md

Purpose

The purpose of the Critical Logging Tiering Methodology is to support GitLab in categorizing logs based on their effect on GitLab's SaaS subscriptions and the achievement of GitLab's mission and goals. Ultimately, this provides GitLab with a mechanism to take a proactive approach to comprehensive risk management which considers risks, such as information security and privacy risks, impacting business operations across the organization. Additionally, by

classifying logging into specific tiers, GitLab will be in a better position to appropriately prioritize risk mitigation activities and tailor internal controls based on a log's related tier.

Scope

The Critical Logging tiering methodology is applicable to all systems utilized across GitLab which are tracked within the Tech Stack to ensure that all systems are vetted completely and accurately using a consistent and standardized methodology.

Roles and Responsibilities

Role	Responsibility
-----	-----
Security Logging Team	Executes an annual review of Critical Logging tiers and makes adjustments as necessary. Owns the Critical Logging Tiering Methodology and supports the identification of and assignment of a Critical Logging tier as needed.
SIRT	Supports defining of Critical Logging tier in conjunction with the Security Logging Team when new systems are added to the tech stack.
AppSec	Supports defining of Critical Logging tier in conjunction with the Security Logging Team when new systems are added to the tech stack.
InfraSec	Supports defining of Critical Logging tier in conjunction with the Security Logging Team when new systems are added to the tech stack.
Technical System Owners	Provide complete and accurate data about the systems that they own so that an accurate tier is assigned.

Critical Logging Tiering Procedure

Defining what Critical Logging means at GitLab can be complex given the nature of our environment and the amount of integrations that exist across the many systems that are used to carry out business activities. As part of GitLab's Business Impact Analysis (BIA) process, we obtain inputs that assist in the assignment of a critical system tier per system. These inputs used to determine system criticality tiers include, but are not limited to, the following:

1. If the system was compromised, would there be an immediate impact to GitLab.com SaaS subscriptions
1. If the system was compromised, which would describe the impact to GitLab:
 - Critical business functions (i.e., indirectly affects revenue generation, requires constant availability for effective business operation)
 - Operational business functions (i.e., affects efficiency/cost of operation)
 - Administrative functions (i.e., affects GitLab team members only on an individual basis (e.g., quality of life, individual productivity))

Once the information is obtained, it is reviewed by the Security Risk and/or IT Compliance Team to determine which system tier should be assigned to the system.

Then the Security Logging Team with the support of SIRT/AppSec/InfraSec takes the output of the findings above and applies the guidelines described below in Determining Critical Logging Tiers to each log source.

Determining Critical Logging Tiers

Systems are assigned a Critical Logging tier based on the following matrix:

```
<style type="text/css">
.tg {border-collapse:collapse;border-spacing:0;margin:0px auto;}
.tg td{border-color:black;border-style:solid;border-width:1px;overflow:hidden;padding:10px
5px;word-break:normal;}
.tg th{border-color:black;border-style:solid;border-width:1px;overflow:hidden;padding:10px
5px;word-break:normal;}
.tg .tg-zqun{background-color:ffffff;color:000000;text-align:center;vertical-align:middle}
.tg .tg-knp3{background-color:6e49cb;border-color:000000;color:ffffff !important;;
text-align:center;vertical-align:middle}
.tg .tg-clye{background-color:380d75;color:ffffff;font-weight:bold;text-align:center;vertical-
align:middle}
.tg .tg-fecx{background-color:cccccc;color:000000;font-weight:bold;text-align:center;vertical-
align:middle}
.tg .tg-cc97{background-color:380d75;color:ffffff;text-align:center;vertical-align:middle}
.tg .tg-dxvi{background-color:6e49cb;color:ffffff;font-weight:bold;text-align:center;vertical-
align:middle}
.tg .tg-e02t{background-color:ffffff;border-color:000000;color:000000 !important;;
font-weight:bold;text-align:center;vertical-align:middle}
.tg .tg-9hzb{background-color:FFF;font-weight:bold;text-align:center;vertical-align:top}
</style>
<table class="tg">
<tbody>
<tr>
<td class="tg-clye">Critical Logging Tier (CST) <span style="color:DB3B21;"></span></td>
<td class="tg-dxvi">CST Description</td>
<td class="tg-dxvi">Example</td>
<td class="tg-fecx">Previous CST Tier Mapping</td>
</tr>
<tr>
<td class="tg-e02t">Tier 1 Mission Critical<span style="color:DB3B21;"></span></td>
<td class="tg-zqun">Systems that have an immediate and significant impact to the security
of GitLab and/or contains red customer data.</td>
<td class="tg-zqun">Cloudflare, GitLab.com, Teleport</td>
<td class="tg-zqun">Tier 1 Product</td>
</tr>
<tr>
<td class="tg-e02t">Tier 2 Business Critical<span style="color:DB3B21;"></span></td>
<td class="tg-zqun">Systems that have an immediate and significant impact to critical
business functions and customer service and/or contain orange data.</td>
<td class="tg-zqun">customers.gitlab.com/subscription, Netsuite, Salesforce</td>
<td class="tg-zqun">Tier 1 Business and Tier 2 Core</td>
</tr>
<tr>
<td class="tg-e02t">Tier 3 Business Operational</td>
<td class="tg-zqun">Disruption affects operational business functions, negatively impacting
efficiency/cost of operation across departments and/or systems contain yellow data</td>
```

<td class="tg-zqun">Clearwater, PagerDuty</td>
<td class="tg-zqun">Combination of Tier 2 Support and Tier 3 Non-critical and influenced by responses to BIA</td>
</tr>
<td class="tg-e02t">Tier 4 Administrative</td>
<td class="tg-zqun">Affects GitLab team members only at an individual level (e.g., quality of life, individual productivity)</td>
<td class="tg-zqun">Donut, JetBrains, LinkedIn Learning, Modern Health</td>
<td class="tg-zqun">Combination of Tier 2 Support and Tier 3 Non-critical and influenced by responses to BIA</td>
</tr>
</tbody>
</table>

{{% panel header="Note" header-bg="primary" %}}

\ As an extension of tiering methodology, the Data Classification Standard prescribes specific Security and Privacy control requirements for each data classification level. These requirements should be followed based on a system's data classification, regardless of the system's tier.

\ By default, any system that contains RED Data per the Data Classification Standard OR is a Third Party Sub-Processor will be a Tier 1 Mission Critical system. This is due to the fact that this data is customer owned and uploaded and as such, has been deemed to be mission critical in nature.

\ By default, any system in-scope for SOX will be a Tier 2 Business Critical system, at minimum.

{{% /panel %}}

Why does GitLab need this methodology?

Tiering systems utilized across GitLab enables team members to make decisions on prioritizing work related to a specific system(s) based on the assigned tier. As an example, if multiple risks have been identified over a wide variety of systems and require remediation, impacted team members can leverage the assigned Critical Logging tiers to make a decision on how to prioritize remediation activities. This methodology will also provide GitLab with a mechanism to easily identify those systems which are most critical across the organization so that we can proactively protect, log and secure those systems.

Maintaining Critical Logging Tiers

A Critical Logging assessment is performed on an annual cadence in alignment with the StORM annual risk assessment process to validate existing systems in GitLab's environment and make adjustments to assigned tiers accordingly. A system's assigned tier can be found in the techstack.yml file. A systems logging inventory can be found in the SecLogging Inventory Repository

Exceptions

Systems that are exempt from this methodology include any system which carries a data classification of Green. All remaining systems which store or process YELLOW, ORANGE, or RED data are required to have a Critical Logging tier assigned. Data classification will be validated to corroborate that the data stored or processed by the system is truly Green data, per the Data Classification Standard.

References

- Business Impact Analysis
- Data Classification Standard

SECTION: security/security-operations/signals-engineering/_index.md

Engaging Signals Engineering

Teams can engage Signals Engineering by heading over to the signals-engineering slack channel. SIRT can also engage Signals Engineering for detection and alert tuning needs by selecting the "report a bug" feature in GUARD.

Our Vision

Ensuring cybersecurity incidents never go undetected by building and maintaining a best in class signal development and detection engineering program.

Our Mission Statement

Build and Mature A Best In Class Detection Engineering Program

- Constantly tracking and pursuing KPI goals, including: Detection coverage, detection precision and sensitivity and time to detection
- Building and maintaining automations with Threat Intelligence and the Red Team to programmatically evaluate detection capabilities and improve our threat resilience

Reducing Time to Detection

- Improving detection context and quality
- Reducing the time to detect through comprehensive detection coverage

Improving Security Observability

- Partnering with the Product, Engineering and Infrastructure teams to improve GitLab security signals
- Partnering with CorpSec and ProdSec to improve security signals in corporate, cloud, and identity infrastructure

Providing Customer Value

- Improving customer facing detection capabilities and offerings

- Identifying & partnering stakeholders to implement customer observability needs

The Team & Priorities

Team Members

Team Member	Role
Matt Coons	Security Manager
Harjeet Sharma	Staff Security Engineer, Signals Engineering
Evan Baltman	Security Engineer, Signals Engineering

Our Stakeholders

While Signals Engineering has dedicated engineers focussed on advancing projects and handling operational duties, there are a number of stakeholders both within the Security Division and beyond that Signals Engineering collaborate with to drive results.

Stakeholder	Shared Responsibilities/Dependencies
SIRT	Detection tuning, new detections, GUARD DaC framework
T&S	Omamori integration
Security Logging	Security logging capabilities & collaboration
Threat Intel	Threat driven detections, Top threat actor detections
GitLab Customers	Consumer of customer facing detections
Product team	Collaboration to improve security signal capabilities
CorpSec	Collaboration to collect signals from purchased tooling
Security Identity Team	Collaboration to collect signals from purchased tooling
Red Team	Collaboration to collect signals from purchased tooling
Product Security	Collaboration to collect signals from purchased tooling

Current Priorities

In the first 6 months (FY25Q4 - FY26Q1), we are focusing on "Low hanging fruit" and establishing the Signals Engineering program.

Some highlights include:

1. Reducing alert false positives & improving FP alerting/handling workflow
2. Initial metrics creation & label standardization
3. Improving customer facing detection creation & sharing process
4. Writing new detections to close identified detection gaps

As the program matures, we will expand our focus to improve our automation and maturity as well as bolstering our customer detection capabilities.

What we've Built & Services we Offer

GUARD

GUARD (GitLab Universal Automated Response and Detection) is the Security Team's Detections as Code (DaC) pipeline and alerting automation framework. GUARD hands off an alert to the SIRT incident handling process stops when an alert is converted into a SIRT incident.

GUARD is a shared responsibility model between Signals Engineering and SIRT - Both SIRT and Signals Engineering build threat detections and have the ability to commit new and maintain existing detections in GUARD.

Threat Detection Tuning

When SIRT identifies a threat detection that needs to be tuned, tuning requests are submitted to the Signals Engineering team for improvements.

Threat Detection Creation

The Signals Engineering team tracks detection coverage and builds new threat detections based on several needs:

1. Gaps in detection capabilities as identified by SIRT or Signals Engineering
2. Collaboration with T&S to improve the ability to identify potential abuse on the GitLab platform
3. New detections for new log sources that can be queried in GitLab's SIEM
4. New attacker TTPs
5. Collaboration with the Red Team as part of purple team or stealth engagements

Signals & Detection Research

Signals engineers conduct deep dive research into potential observability gaps and signals enhancement opportunities, identified in the GitLab product and 3rd party tools GitLab uses. Such research assignments have a target deliverable of new detections as well as improved observability capabilities.

How We Measure Success

We measure the success of Signals Engineering by collecting and reporting on key performance indicators, through metrics collected from MRs, issues and alerting metrics.

Initial metrics we report on are listed below:

Alerting & Tuning

1. TP/FP ratio + trending
2. Alert Bug report volume

Incidents

1. Number of S1 incidents with signal gaps

Value for Customers

1. Number of public detections

Detection coverage

1. MITRE coverage
2. Coverage by log sources
3. MTTDC (Mean time to detection creation)
4. Coverage by threat actor

Metric Labels

- SET::Detection-New
- SET::Detection-Maintenance
- SET::Research
- SET::Signals-Improvement
- SET::Cross-Functional
- SET::Signal-Gap

SECTION: security/security-operations/sirt/_index.md

The Security Incident Response Team - SIRT is on the forefront of security events that impact both GitLab.com and GitLab the company.

<i class="fas fa-rocket" id="biz-tech-icons"></i> Our Vision

To detect security incidents before they happen and to respond promptly when they do happen.

Our Mission Statement

Ensure maximum operational uptime of mission critical infrastructure and informational assets in its daily operations. This mission is achieved by providing effective crisis response, timely distribution of security notifications, continuous monitoring of potential issues, postmortem of major incidents for training and environmental awareness.

<i class="fas fa-users" id="biz-tech-icons"></i> The Team

Team Members

Mitra Jozenazemian	Security Manager
Nicholas Slaughter	Senior Security Manager
Robbie Dickson	Security Manager

Bala Allam	Senior Security Engineer
Chathura Kuruwita	Senior Security Engineer

Ellis Coulson	Security Engineer
Hasan Chawich	Security Engineer
Janina Roppelt	Senior Security Engineer
Jason Hawkins	Senior Security Engineer
Laurens Van Dijk	Senior Security Engineer
Leslie Anzures	Security Engineer
Neil McDonald	Senior Security Engineer
Sean Gillespie	Senior Security Engineer
Valentine Mairet	Staff Security Engineer
Yunus Khan	Senior Security Engineer
Saksham Anand	Security Engineer

Services We Provide

1. Reactive - Services design to respond to active incident handling, including but not limited to

- Incident analysis
- Incident response support and coordination
- Incident response resolution
- Detection and response engineering

1. Proactive - Services designed to improve the infrastructure and security processes of GitLab before any incident occurs or is detected. The main goals are to avoid incidents and to reduce the impact and scope when they do occur.

- Cyber Threat Analysis of vulnerability warnings and security advisories
- Monitor Adversaries' activities and related trends to help identify future threats
- Configuration and maintenance of security tools, applications, and infrastructure
- Detection and response engineering

1. Administrative - Services design to assist with requests from GitLab's Legal and HR Departments.

Engaging SIRT

The SIRT is on-call 24/7/365 to assist with any security incidents. If an urgent security incident has been identified or you suspect an incident may have occurred, please refer to Engaging the Security Engineer On-Call.

Information about SIRT responsibilities and incident ownership is available in the SIRT On-Call Guide.

Incident Management and Review

As part of the incident management and review process the SIRT maintains a recurring meeting that takes place on Monday of each week. During this meeting all of the previous weeks incidents, and any incidents that are currently open are reviewed. The review process covers the incident's scope, impact, the work performed to mitigate and remediate the incident, next steps, blockers, and current status. These meetings are also an opportunity to discuss mishandled incidents and process improvements.

Limited Access

Information about security incidents or investigations is considered limited access and is not shared with all team members by default. Security incidents are handled with appropriate confidentiality protocols to protect potentially sensitive information and maintain operational security.

The workflow for security incident handling is:

```
mermaid
graph TD
    A[Security incident occurs] --> B[Incident reported]
    B --> C[SIRT automation creates a private project]
    C --> D[SIRT automation creates issue in new project]
    D --> E[Reporter added to the issue/project]
    E --> F[Other team members are added as needed]
```

A pre-defined list of team members are automatically added when the incident is ~severity::1.

SECTION: security/security-operations/sirt/engaging-security-on-call.md

Overview

The Security Incident Response Team (SIRT) is on-call 24/7/365 to assist with any security incidents. This handbook provides guidance to help identify the scope and severity of a potential security incident, followed by instructions on how to engage the Security Engineer On-Call (SEOC) if needed.

Information about SIRT responsibilities and incident ownership is available in the SIRT On-Call Guide.

Incident Severity

Before engaging the SEOC, please review our severity and priority levels to ensure that the incident has been assigned the appropriate level of response.

For phishing related issues, see Phishing. For other non-urgent issues, see Low Severity Issues/

Note: Additional information on Recovery Time Objective (RTO) and Recovery Point Objective (RPO) is available on the BPC Handbook page

The following items are out of scope for SIRT and should be escalated to the respective teams mentioned below:

- Vulnerability reports and HackerOne: please escalate to Application Security
- Abuse reports and DMCA notices: please escalate to Trust & Safety
- General Customer Inquiries: please escalate to Field Security
- Self-Managed Instances: please escalate to [TBD]

Low Severity Issues

For general Q&A, GitLab Security is available in the security channel in GitLab Slack.

For low severity, non-urgent issues, SIRT can be reached by mentioning @sirt-members in Slack or by requesting the incident form link, using the /security slash command in Slack. (Note: this command does not work inside Slack threads)

Please be advised the SLA for Slack mentions is 6 hours on business days.

Phishing

If you suspect you've received a phishing email and have not engaged with the sender, please see: What to do if you suspect an email is a phishing attack.

If you have engaged a phisher by replying to an email, clicking on a link, have sent and received text messages, or have purchased goods requested by the phisher, please engage the SEOC.

Engage the Security Engineer On-Call

If you have identified a security incident or you need immediate assistance from the SIRT:

- Slack: use the /security slash command

The Slack command triggers SIRT's Escalation Workflow. You will be sent a link to file a security incident using a Tines webform. This form asks questions about the incident that help the SIRT automatically determine severity and priority. Depending on which labels get assigned, the SEOC will be paged.

For more information on how the form is processed and labels are assigned, consult SIRT's incident classification methodology.

The workflow uses your answers to create a new issue and track the reported incident. Please provide as many details as possible when answering the open questions to aid the SEOC in their investigation of the incident. If you do not receive a link to the incident issue, please contact a SIRT engineer (see next paragraph).

For small requests like an indication if something is a security issue, questions on ongoing incidents or SIRT FYIs, team members can use:

- @sirt-oncall

This tags the current on call engineer.

If the security incident prevents you from accessing Slack:

- Email: send an email with a brief description of the issue to panic@gitlab.com

The SEOC will engage in the relevant issue within the appropriate SLA. If the SLA is breached,

the Security Manager On-Call (SMOC) will be paged. Paging the SEOC via email also creates a new issue to track the incident being reported. You may provide a detailed explanation of the incident directly in the issue.

If paged, the SEOC will typically respond within 15 minutes and may have questions which require synchronous communication from the incident reporter. It is important when paging the SEOC that the incident reporter be prepared and available for this synchronous communication in the initial stage of the incident response.

SECTION: security/security-operations/sirt/sec-incident-response.md

Purpose

The Security Incident Response Team (SIRT) is on-call 24/7/365 to assist with any security incidents. If an urgent security incident has been identified or you suspect an incident may have occurred, please refer to Engaging the Security Engineer On-Call and use the Slack /security command by writing a new message to either yourself, or a public/private channel in Slack (this command does not work inside Slack threads), typing the following command and pressing enter:
/security

Information about SIRT responsibilities and incident ownership is available in the SIRT On-Call Guide.

Scope

Incident Identification

Security incident investigations are initiated when any security event is detected on GitLab.com, on another GitLab service, or as part of the GitLab company. These investigations are triaged by qualified Security team members and dispositioned as false positives when the triage evidence is obvious and risk-free. If there is any question about the event being potentially harmful or negatively impactful to GitLab customers, services, products, team members, 3rd party services, or alike, the Security team investigates the incident.

Incident indicators can be reported to SIRT either internally, by a GitLab team member, or externally. It is the Security team's responsibility to determine when to investigate dependent on the identification and verification of a security incident.

The GitLab Security team identifies security incidents as any violation, or threat of violation, of GitLab security, acceptable use or other relevant policies.

SIRT will follow processes in the Material Breach Determination internal handbook page for any security incidents that individually, or in aggregate may be a material breach, including 3rd party breaches that may have a material impact to GitLab. Incidents that have the potential to be material will be treated as MNPI.

Roles & Responsibilities

Role	Responsibilities
GitLab Team Members	Responsible for following the requirements in this procedure
SIRT	Responsible for implementing and executing this procedure
SIRT Management (Code Owners)	Responsible for approving significant changes and exceptions to this procedure

Procedure

Incident Response Process: this guide covers the following activities for all security incidents

1. Detection

- The SIRT, other internal, or external entity identifies a Security or Privacy event or risk that may be the result of a potential exploitation of a Security Vulnerability or Weakness, or that may be the result of a misconfiguration, or an innocent error
- One of our Security detection controls identifies event(s) outside of the established security baseline
- A security issue is escalated into an incident out of an abundance of caution and to validate any assumptions

1. Analysis

- SIRT determines whether the reported security or privacy event is in actuality security or a privacy event
- SIRT determines the incident severity and priority based on the following incident classification methodology

1. Containment

- Prevent the spread of unauthorized or malicious use of the affected system or data
- Mitigates and eventually fully remediates the root cause of the incident to prevent further damage or exposure
- SIRT may implement additional controls to minimize the damage as a result of the incident
- Determine if it is safe to continue operations with the affected system
- Permit or deny the operations of the affected system

1. Eradication

- Components that have caused the security incident are eliminated
- Removal of the attackers' access to the environment or the targeted system
- Strengthen the controls surrounding the affected system

1. Recovery

- Represents the effort to restore the affected system's operations after the problem that gave rise to the incident has been corrected
- Implementation of additional monitoring controls
- Update the incident record with any relevant details

1. Post-Incident analysis and activities

- Retrospective and lessons learned activity

Leaked Secrets Incident Response Process

When secrets are confirmed to be leaked, it is important to minimize the exposure time by immediately revoking the secrets. This can be done by automation or manual revocation by the Security team. Security will immediately revoke the secrets to prevent further abuse even if the potential impact of that action isn't clearly understood at that time. In some cases this

may cause disruption, when the secrets are being used for legitimate processes. Because of this potential for impact to services dependent on the revoked secrets, Security posts a notification to the security-revocation-self-service Slack channel, where secrets owners can use the channel for manual or automated self-service. Since secret has already been exposed and revoked, and to make it easier for secrets' owners to find their secrets in the channel, the clear text version of the revoked secret is published as a part of the notification.

Confidentiality

Security incidents may (and usually do) involve sensitive information related to GitLab, GitLab's customers or employees, or users who (in one way or another) have engaged with GitLab. GitLab, while codifying the Transparency value, also strongly believes in and strives to maintain the privacy and confidentiality of the data its employees, customers, and users have entrusted us with.

A confidential issue means any data within the issue and any discussions about the issue or investigation are to be kept to a need to know basis. This will involve specific GitLab employees only unless permission is explicitly granted by GitLab Legal, a GitLab Security Director, a VP of Security, or scoped incident labels GitLab Executive Team.

Which team members have access to a specific incident is defined on a case to case basis by SIRT according to our limited access policy. Whenever a team member needs access to the incident, this should be requested in the corresponding incident channel or in security-operations. Bypassing security controls to access the incident issue will result in Security Operations being notified.

Incident Tracking

Security incident investigations are opened in the SIRT group. The project will be created using the Incident Response project template and the incident issue template. To create the incident, the /security command in Slack has to be used over manual creation. Please refer to the Engaging the Security Engineer On-Call page for further detail.

All artifacts from an investigation must be handled per the Artifact Handling and Sharing internal handbook page.

NOTE: The tracking issue, any collected data, and all other engagements involved in a Security Incident must be kept strictly confidential.

Incident Severity

Assigning severity to an incident isn't an exact science and it takes some rational concepts mixed with past experiences and gut feelings to decide how bad a situation may be. When considering severity, look at:

- The type of data involved and how it's classified using the Data Classification Policy
 - Was this data leaked or disclosed to parties who should not have visibility to it?
 - Has the data been modified in our records? (either confirmed or believed to be)
- Was a user or service account taken over?
 - What level of access did this account have and to what services or hosts?

- What actions were taken by the compromised account?
- If a vulnerability is present on a host or service, consider the impact it might have on GitLab and the likelihood of it being exploited by using the Risk Factors and Risk Scoring documentation.
 - Was the vulnerability exploited? If so, how was it used and how frequently?
- What is the scope of the incident?
 - How many GitLab.com users were/may have been impacted?
 - How many hosts or services?
- Has this incident resulted in any hosts or services being unavailable?

To help place the correct severity rating on the incident you are about to submit, please refer to the Incident Classification page.

Internal Engagement & Escalation for High-Severity Incidents

Coordinate with internal teams and prepare for the incident investigation:

- Open an incident-focused Slack channel to centralize non-verbal discussion, particularly if the incident is of a sensitive nature. This is done by using `/sirt-escalate` in slack.
- For artifact handling, a Google Drive folder and shared Google Doc should have been created automatically and linked to the issue.

In the event that an incident needs to be escalated within GitLab, the Security Engineer On Call (SEOC) will page the Security Incident Manager On Call (SIMOC). It is the responsibility of the SIMOC to direct response activities, gather technical resources from required teams, coordinate communication efforts with the Communications Manager On Call, and further escalate the incident as necessary.

Characteristics of an incident requiring escalation include but are not limited to the following:

- Incidents involving or likely to involve data with an Orange or Red classification
- Incidents that are likely to impact, or are actively impacting the availability or functionality of essential services
- Incidents affecting legal or financial resources
- Incidents that are likely to require a breach notification or public notification
- Incidents involving criminal activity or that may require the involvement of law enforcement
- Incidents involving key personnel such as executive leadership

Often a security incident may revolve around a particular GitLab feature where coordination with the respective engineering team is required to gather in-depth understanding of implementation or mitigation. The EM/PM for those teams should be looped in and depending on the severity of the issue (Severity 1 or Severity 2) consider setting up follow the sun coverage from the engineering counterparts. This will allow for quick remediation or engineering assistance as situation may evolve on security incident.

If applicable, coordinate the incident response with business contingency activities.

Containment

Once an incident has been identified and the severity has been set, the incident responder must attempt to limit the damage that has already occurred and prevent any further damage from occurring.

The first step in this process is to identify impacted resources and determine a course of action to contain the incident while potentially also preserving evidence. Containment strategies will vary based on the type of incident but can be as simple as marking an issue confidential to prevent information disclosure or to block access to a network segment.

It's important to remember the containment phase is typically a stop-gap measure to limit damage and not to produce a long term fix for the underlying problem. Additionally the impact of the mitigation on the service must be weighed against the severity of the incident.

When triaging priority::1/severity::1 incidents there may be times that SIRT or Infrastructure are unable to mitigate an issue, or identify the full impact of a potential mitigation. In these cases the Development Escalation Process can be used to engage with the development team on-call. It is important that this process is followed as documented and only for priority::1/severity::1 issues.

Remediation and Recovery

During the remediation and recovery phase the incident responder will work to ensure impacted resources are secured and prepared to return the service to the production environment. This process may involve removing malicious or illicit content, updating access controls, deploying patches and hardening systems, redeploying systems completely, or a variety of other tasks depending on the type of incident.

An Incident Review will be completed for all incidents. To prevent future occurrences and better our security posture, incident retrospectives will be conducted for all severity::1 incidents and others where there is indication for added value.

This phase should prioritize short term changes that improve the overall security of impacted systems while the full recovery process may take several months as longer term improvements are developed.

Resolution

Upon completing the containment, remediation, communication and verification of impacted services, the incident will be considered resolved and the incident issues may be closed after a review.

The incident response process will move on to a retrospective and lessons learned phase through which the process improvements and overall security of the organization can be analyzed and strengthened.

Internal & External Communication

Our security incident communication plan defines the who, what, when, and how of GitLab in notifying internal stakeholders and external customers of security incidents.

Engaging Law Enforcement

If during the course of investigating a security event the incident itself, materials involved in the incident (stored data, traffic/connections, etc), or actions surrounding the incident are deemed illegal in the United States, it may be necessary (and advisable) to engage U.S. law enforcement.

1. The Security Engineer On-Call will immediately escalate to the Security Operations Manager On-Call and the VP of Security Operations to raise awareness of the legal concern.

1. Following review, the VP of Security Operations will engage the CISO of Security and VP of Legal for validation of next steps.

1. The VP of Security Operations will then contact the appropriate local law enforcement agencies, state agencies or US (federal) government agencies.

When You Join an Incident Channel or Call

In the event of a perceived major security incident (which may prove to not be one at a later point), adhoc communication is sometimes required for coordination. This is outlined in the sections above. If you are identified as someone who could assist during the perceived security incident with either the identification, confirmation, or mitigation of the incident, you will be added to a dedicated Zoom call or Slack channel. Upon joining that call/channel, please take note of the following:

- This is crisis management communication channel, that means that it's private by default. It may contain business critical or PII information that cannot be shared with the larger company at this time, or ever. Should GitLab Security determine that the content of this particular communication channel can be made internally available or public at a later point, the required changes will be made.

- Read the channel history before asking questions. Get some context, read through past conversations and related documents. The relevant person will reach out to you with specific asks at the right time.

- Do your best to stay professional. However, be aware that security incidents are often stressful and we're all humans. People may raise their voice, or use wording that seems unnecessary, harsh or inappropriate. It's important to cut people some slack (no pun intended) during this stressful time, and raise/address any potentially erratic behavior with the relevant manager once the incident is over.

- Humor is your ally. No, it really is.

Incident Labels

Use proper labels. The correct use of dedicated scoped incident labels is critical to the accuracy of the data in the incident tracker and the subsequent metrics calculated from it. A list of all labels can be found in the GitLab SIRT group internal handbook page.

Exceptions

Exceptions to this procedure will be tracked as per the Information Security Policy Exception Management Process.

References

- Security Communications Runbooks (internal)
- Incident Communications Plan
- Marketing Emergency Response process

SECTION: security/security-operations/sirt/security-incident-communication-plan.md

Purpose

GitLab takes the security of our clients' information extremely seriously, regardless of whether it's on GitLab.com or in a self-managed instance. In keeping with GitLab's value of transparency we believe in communicating about security incidents clearly and promptly.

Scope

This communication response plan maps out the who, what, when, and how of GitLab in notifying and engaging with internal stakeholders and external customers on security incidents. This plan of action covers the strategy and approach for security events which have a 'high' or greater impact as outlined in GitLab's risk scoring matrix.

Roles & Responsibilities

Role	Responsibilities
GitLab Team Members	Responsible for following the requirements in this procedure
SIRT	Responsible for implementing and executing this procedure
SIRT Management (Code Owners)	Responsible for approving significant changes and exceptions to this procedure

Procedure

What is an incident?

The GitLab Security team identifies security incidents as any violation, or threat of violation, of GitLab security, acceptable use or other relevant policies. You can learn more about how we identify incidents in the GitLab security incident response guide.

- Corporate incident response

For Support or Infrastructure managed incidents where external communication guidance is needed, please see the corporate communications incident response plan and engage that team via external-comms in slack.

- Infrastructure incident response

For Infrastructure incidents, please follow the infrastructure incident management and communication process.

Defining the scope/severity of an incident

The Security Engineer On-Call will determine the scope and severity and potential impact of the security incident. Once the potential impact has been determined, implementation of the appropriate internal and external communications strategy should begin.

Roles and responsibilities in a Security incident

Security team roles and responsibilities

| Role | Responsibilities |

| ---- |----- |

| Security Engineer on Call (SEOC): | This is the on-call Security Operations Engineer. The individual is the first to act, validate, and begin the process of determining severity and scope. |

| Security Incident Manager on Call (SIMOC): | This is a Security Engineering Manager who is engaged when incident resolution requires coordination across multiple parties. The SIMOC is the tactical leader of the incident response team, typically not engaged to perform technical work. The SIMOC assembles the incident team by engaging individuals with the skills, access, and information required to resolve the incident. The focus of the SIMOC is to keep the incident moving towards resolution, keeping stakeholders informed and performing SecCMOC duties. |

| Security Communications Manager on Call (SecCMOC): | This is the Security Incident Manager On-Call (SIMOC), Security Incident Commander or Security Assurance Engineer who will coordinate external communications efforts according to this security incident response plan and liaise across the extended GitLab teams to ensure all parties are activated, updated and aligned. |

| Security External Communications: | This function partners with and advises incident response teams in reviewing and improving messaging for external audiences (including customers, media, broader industry). This role liaises with marketing teams for any necessary reviews or messaging deployment. This function should be engaged once first draft content has been developed using the Security incident external response issue template. |

More about the CMOC responsibilities

As security practitioners and incident response engineers, our security assurance and security operations teams and engineers are best positioned to develop initial messaging and serve in the CMOC/Communications manager on call role.

Each team-appointed CMOC is the DRI for:

- Opening the Security incident external response issue template and tagging in potential stakeholders and contributors
- Drafting the initial message(s)
- Tracking development and deployment of the various content and
- Identifying key stakeholders for contribution, review and approval (support, security/SIRT leadership, legal, etc)
- Routing and securing approvals from various parties (support, security/SIRT leadership, legal, etc)
- Keeping stakeholders updated and informed on the progress of communications development in the related incident response slack channel and issue(s)

More about the Security External Communications function responsibilities

The Security External Communications function is the DRI for:

- Editing and improving first drafts provided by CMOC
- Advising on appropriate channels and forms of communication needed
- Acting as an approval point on final messaging to ensure it's ready for external use
- Liaising with PR and corporate communications for additional reviews and/or messaging needs (public/media statements)
- Deploying the messaging via collaboration with our PR (media statement), Content Marketing (blog post) and Marketing Operations teams (email response)
- Posting final communications materials to slack channels (developer-relations, socialmediaaction, sales, security-division and customer-success) for awareness and use.
- Support manager on call will manage support team awareness

Extended team roles, responsibilities and points of contact

- Marketing Operations: Responsible for sending incident-related email to impacted parties in a security incident. This group has established a Marketing emergency response process and is engaged by creating an incident communication request using the incidentcommunications template, tagging in the assigned timezone's coverage owner and posting the issue in the mktgops channel in Slack.
 - Marketing Ops can send emails through MailGun or Marketo. This group will determine based on the information provided what the best platform is for distribution. If a custom distribution list needs to be created, the data team may need to be involved.
- Support Team: Using background information and prepared responses provided by the Security Engineer On Call and Communications Manager On Call, our Support Team will triage and respond to cus